

CYBER SECURITY (Professional Elective – II)

UNIT – I

Introduction to Cyber Security: Basic Cyber Security Concepts, layers of security, Vulnerability, threat, Harmful acts, Internet Governance – Challenges and Constraints, Computer Criminals, CIA Triad, Assets and Threat, motive of attackers, active attacks, passive attacks, Software attacks, hardware attacks, Spectrum of attacks, Taxonomy of various attacks, IP spoofing, Methods of defense, Security Models, risk management, Cyber Threats-Cyber Warfare, Cyber Crime, Cyber terrorism, Cyber Espionage, etc., Comprehensive Cyber Security Policy.

Introduction to Cyber Security:

Cyber Security is the [practice of protecting systems, networks, and data](#) from digital attacks.

These attacks are often aimed at [accessing, changing, or destroying sensitive](#) information; [extorting](#) money from users; or [interrupting](#) normal business processes.

As our world becomes more digitally connected—through computers, mobile phones, the internet, and cloud computing—[cyber threats](#) have also grown in scale and complexity.

Cyber security helps individuals, companies, and governments defend against these threats.

Why Cyber Security is Important

1. **Protects sensitive data** – such as personal information, financial records, or medical records.
2. **Prevents cyber attacks** – including hacking, malware, ransomware, phishing, and more.
3. **Maintains system integrity** – ensuring systems work correctly and aren't tampered with.
4. **Supports business continuity** – by preventing service disruptions and loss of trust.
5. **Complies with laws and regulations** – such as GDPR, HIPAA, etc. legal rules for protecting data.

GDPR (General Data Protection Regulation) is a privacy law created by the European Union to protect the personal data of people living in Europe.

It came into effect on **25 May 2018**.

What is Personal Data?

Anything that can identify a person:

- ✓ Name
- ✓ Email address
- ✓ Phone number
- ✓ Address
- ✓ IP address
- ✓ Aadhaar-like identification numbers
- ✓ Location information

Main GDPR Principles

1. Get Permission Before Collecting Data
2. Right to Access Data
3. Right to be Forgotten
4. Data Breach Notification

GDPR Penalties

Violations can lead to huge fines.

What is HIPAA?

HIPAA (Health Insurance Portability and Accountability Act)

is a law in the **United States** that protects medical and health information.

It applies to:

- ✓ Hospitals
- ✓ Doctors
- ✓ Clinics
- ✓ Health insurance companies

What Information Does HIPAA Protect?

Examples:

- ✓ Medical history
- ✓ Test reports
- ✓ X-rays
- ✓ Prescriptions
- ✓ Hospital records

HIPAA Rules

- ✓ **Privacy Rule**

Only authorized people can see medical records.

- ✓ **Security Rule**

Hospitals must protect electronic health records.

Methods include:

- Passwords
- Encryption
- Access control

HIPAA Violations

If a hospital leaks patient information:

Fines may apply

Legal action may occur

Reputation is damaged

What is Phishing?

Phishing is a type of cyber-attack where attackers impersonate legitimate organizations or individuals through emails, messages, or websites to trick victims into revealing confidential information.

How Phishing Works:

1. **Bait:** An email, message, or website that looks real is sent to the victim.
2. **Hook:** The message contains a link or attachment prompting action (e.g., “Update your

account now!”).

3. **Catch:** Once clicked, it may lead to a fake login page or download malware.
4. **Theft:** The attacker captures login credentials, financial data, or installs spyware.

Common Types of Phishing

1. Email Phishing

Fake emails pretending to be from banks, companies, or government agencies.

2. SMS Phishing (Smishing)

Fake text messages.

Example:

Your KYC has expired. Click here to update.

3. Voice Phishing (Vishing)

Attackers call victims pretending to be bank employees or support staff.

4. Spear Phishing

Targeted phishing aimed at a specific person or organization.

Example:

An email addressed personally to a company manager.

Types of Malware

1. Virus

A virus attaches itself to a legitimate file or program.

When the infected file is opened, the virus spreads.

Example:

A USB drive contains an infected file. When someone opens it, the virus spreads to the computer.

2. Worm

A worm spreads automatically across networks without user action.

Example:

The worm infects one computer in an office and automatically spreads to dozens of others.

3. Trojan Horse

A Trojan pretends to be useful software but contains malicious code.

Example:

Someone downloads a "Free Photoshop Cracked Version."

The program installs successfully, but it secretly steals passwords.

4. Ransomware

Ransomware encrypts files and demands money for decryption.

Example:

A company's documents suddenly become inaccessible.

A message appears:

"Pay ₹5,00,000 within 72 hours to recover your files."

5. Spyware

Spyware secretly monitors user activity.

Example:

It records:

Websites visited

Keystrokes

Passwords entered

and sends them to attackers.

6.Adware

Displays unwanted ads

Pop-ups from free software

How Ransomware Works:

1. **Infection** – Often through phishing emails, malicious downloads, or weak network security.
2. **Encryption** – Important files are encrypted or locked.
3. **Ransom Note** – A message appears demanding payment to unlock files.
4. **Payment** – Victims are pressured to pay, but there's no guarantee of file recovery.

How to Protect Against Ransomware:

- Backup your data regularly
- Do not click on unknown email links or attachments
- Keep your software and OS updated
- Use antivirus and firewall protections
- Disable macros in documents unless needed

Basic Cyber Security Concepts : / What is CIA Triad Explain Briefly?

Cyber security refers to the practices, technologies, and processes designed to protect computers, networks, programs, and data from unauthorized access, attacks, or damage.

The three core principles of cybersecurity are often referred to as the CIA Triad

1. Confidentiality
2. Integrity
3. Availability

1. Confidentiality

Meaning: Ensuring that information is only accessible to authorized users.

Goal: Prevent unauthorized access or disclosure of data.

Examples:

- ✓ Using passwords to protect your email or mobile phone.
- ✓ Encrypting sensitive data like Aadhaar numbers or credit card details.
- ✓ A university stores student records that only staff can access using login

2. Integrity

Meaning: Ensuring the accuracy and consistency of data over its lifecycle.

Goal: Prevent unauthorized modification or tampering of data.

Examples:

- ✓ When you send money via UPI, the amount must not change during the transaction.
- ✓ Using hashing to verify files (like antivirus checksums).
- ✓ If a company's employee salary database is altered by a hacker, integrity is violated.

3. Availability

Meaning: Ensuring that authorized users have access to data and services when needed.

Goal: Keep systems and networks running smoothly without disruption.

Examples:

- ✓ Online banking should be available 24/7 without outages.
- ✓ Backup servers and UPS (Uninterruptible Power Supply) to prevent downtime.
- ✓ During college admissions, the website must stay online despite heavy traffic.

<u>Concept</u>	<u>Definition</u>	<u>Real-world Example</u>
Confidentiality	Protecting data from unauthorized access	Password-protected documents
Integrity	Ensuring data is not changed or tampered	Hash checks for downloaded files
Availability	Ensuring services/data are always usable	Website uptime during online exams or transactions

How does the CIA Triad help in designing security systems?

The CIA Triad provides a **basic framework for identifying security requirements and selecting appropriate controls**. When designing a security system, security professionals consider:

- **Confidentiality:** Who should be allowed to access the information?
- **Integrity:** How can we prevent or detect unauthorized modification?
- **Availability:** How can we keep the system operational and recover quickly from failures?

For example, in an **online banking system**, encryption and authentication protect confidentiality, transaction verification and digital signatures help maintain integrity, and backups and redundant systems help ensure availability.

In conclusion, the CIA Triad helps organizations build balanced security systems by protecting information from **unauthorized access, unauthorized modification, and loss of access**.

What are the different layers of security in cybersecurity? Explain each layer with suitable examples.

Layers of Security in Cyber Security :

Cyber security uses multiple "layers" so that if **one security measure fails**, **others are still** in place. Each layer protects against different threats.

1. Physical Security Layer

What it protects: The actual hardware and physical devices (computers, servers, data centers).

How it works: Prevents unauthorized people from physically accessing or damaging equipment.

Examples:

- ✓ Security guards at server rooms
- ✓ CCTV surveillance
- ✓ Locks and access cards

2. Network Security Layer

What it protects: The organization's computer networks (data in transit).

How it works: Prevents unauthorized access, misuse, or attacks on networks.

Examples:

- ✓ Firewalls block suspicious traffic
- ✓ Intrusion Detection/Prevention Systems (IDS/IPS)
- ✓ Using Virtual Private Networks (VPNs)

3. Application Security Layer

What it protects: The software/applications running on systems.

How it works: Safeguards applications from threats like viruses, malware, or software bugs.

Examples:

- ✓ Antivirus and anti-malware software
- ✓ Regular software updates/patches
- ✓ Secure software development practices

4. Data Security Layer

What it protects: The data stored in or processed by systems.

How it works: Ensures data can't be read or tampered with by unauthorized people.

Examples:

- ✓ Encryption of sensitive data
- ✓ Data backups
- ✓ Access controls (permissions for who can view/change data)

5. User (Human) Layer

What it protects: Accounts and activities of people who use the systems.

How it works: Prevents unauthorized people from using accounts and educates users about security risks.

Examples:

- Passwords and Multi-factor Authentication (MFA)
- User training on phishing and scams
- Role-based access (users only see what they need)

Vulnerability & Threats:

A **vulnerability** is a *weakness, bug, misconfiguration, or security gap* in software, hardware, networks, cloud services, AI systems, or human processes that can be exploited by a *threat* actor to compromise confidentiality, integrity, or availability.

Examples

- ✓ Weak passwords
- ✓ Unpatched software
- ✓ SQL Injection vulnerability
- ✓ Misconfigured cloud storage
- ✓ Employees clicking phishing links
- ✓ AI systems with insecure access controls

Threat

A **threat** is any person, group, malware, event, or circumstance capable of exploiting a *vulnerability and causing damage, data theft, financial loss, or service disruption*.

Examples

- ✓ Hackers
- ✓ Ransomware groups
- ✓ Insider threats (Mallicious, Negligent, Compromised Insider)
- ✓ Nation-state attackers
- ✓ AI-powered phishing campaigns
- ✓ Natural disasters affecting data centers

Latest Real-World Examples (2025–2026)

Example 1: Unpatched VPN

Vulnerability

Organization fails to install security updates on its VPN server.

Threat

Ransomware group exploits the flaw.

Impact

Entire company network encrypted and unavailable. Active exploitation of VPN vulnerabilities continues to be a major ransomware entry point.

Example 2: AI-Powered Phishing

Vulnerability

Employees trust realistic emails.

Threat

AI-generated phishing campaigns.

Impact

Credential theft and account compromise. Security reports show increasing use of AI for phishing and social engineering

Example 3: Cloud Misconfiguration

Vulnerability

Publicly accessible cloud storage.

Threat

Cybercriminals searching for exposed data.

Impact

Sensitive information leaked.

$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

Meaning:

No Vulnerability $\rightarrow$ Attack usually fails.

No Threat $\rightarrow$ Vulnerability may remain unused.

High Impact + Active Threat + Vulnerability $\rightarrow$ Critical Risk.

Example:

An outdated operating system that no longer receives security updates is a vulnerability.

Cybercriminals can target this weakness with malware or ransomware attacks, which are threats.

Real-time Example (WannaCry Ransomware Attack, 2017):

The WannaCry ransomware attack exploited a known vulnerability in Microsoft Windows systems (called EternalBlue). This vulnerability allowed the ransomware to spread rapidly and encrypt users' data, demanding a ransom in Bitcoin.

- The vulnerability was a flaw in the SMB (Server Message Block) protocol used by Windows for file sharing.
- Microsoft had released patches for supported systems before the attack, but many organizations had not updated their systems, leaving them exposed (the vulnerability).
- The ransomware (the threat) exploited this flaw to lock files and demand money.
- This attack affected over 300,000 computers in 150 countries, resulting in millions to billions of dollars in damages.

Harmful acts:

Harmful acts are **intentional or unintentional actions** that damage or disrupt digital systems. These acts can include stealing sensitive data, corrupting files, spreading malware, or tricking users into revealing confidential information.

Harmful Act	Description	Real-Time Example
Phishing	Fake emails, messages, or websites used to steal sensitive information.	An email pretending to be from a bank asking for your password.
Malware	Malicious software designed to damage or gain unauthorized access to systems.	A virus that deletes files or spyware that steals data.

Ransomware	Malware that encrypts files and demands payment to restore them.	A hospital's records become inaccessible until a ransom is paid.
Unauthorized Access (Hacking)	Accessing a computer or account without permission.	Logging into someone else's email account without authorization.
Data Theft	Stealing confidential or personal information.	Stealing customer credit card details from a database.
Denial-of-Service (DoS/DDoS) Attacks	Flooding a server with traffic to make it unavailable.	An online shopping website crashes during a sale due to an attack.
Social Engineering	Manipulating people into revealing confidential information.	Someone pretending to be IT support and asking for your password.
Identity Theft	Using another person's information for fraud.	Creating a fake account using someone else's Aadhaar or PAN details.
Insider Threats	Employees misusing their access to harm the organization.	An employee copying confidential company data before leaving.
Website Defacement	Unauthorized modification of a website's content.	A hacker replaces a company's homepage with offensive messages.

Internet Governance – Challenges and Constraints:

Internet Governance (IG) is the process of developing and applying **shared principles, rules, policies, standards, and decision-making procedures** by governments, private companies, technical organizations, and civil society to ensure the **secure, stable, open, and reliable operation of the Internet**.

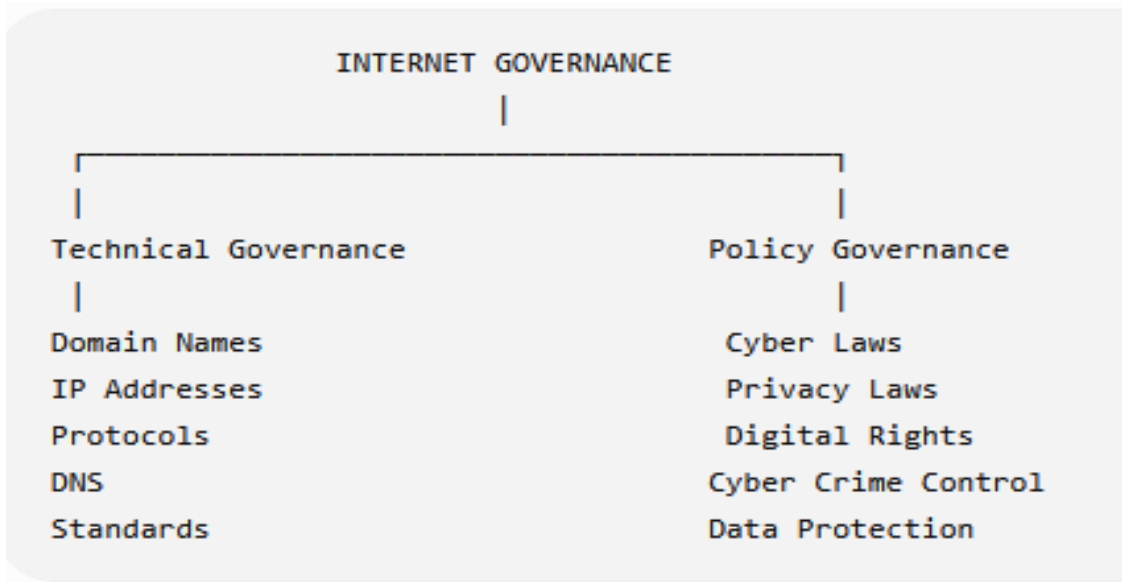
What is the Need for Internet Governance?

The Internet is used by billions of people worldwide. Without proper governance:

- ✓ Cyber crimes would increase.
- ✓ Personal data would not be protected.
- ✓ No common technical standards would exist.
- ✓ Online fraud would become uncontrollable.
- ✓ Countries would struggle to cooperate against cyber attacks.

Therefore, Internet Governance ensures:

- ✓ Security ✓ Privacy ✓ Stability ✓ Accessibility
- ✓ Innovation ✓ Trust



Stakeholder	Role
Governments	Create cyber laws and national policies
Private Companies	Build Internet services and infrastructure
Technical Organizations	Develop Internet standards
Internet Service Providers (ISPs)	Provide Internet connectivity
Cyber Security Experts	Protect networks from attacks
Civil Society	Represent users and digital rights
Educational Institutions	Conduct research and awareness
International Organizations	Promote global Internet cooperation

Components of Internet Governance:

1. Technical Governance
2. Legal Governance
3. Economic Governance
4. Social Governance
5. Security Governance

Challenges in Internet Governance

1. Cyber Crime
2. Data Privacy
3. Data Protection
4. Cyber Warfare
5. Cyber Terrorism
6. Fake News and Misinformation
7. Social Media Abuse
8. Cross-Border Jurisdiction

9. Artificial Intelligence (AI) Internet of Things (IoT)
10. Cloud Computing Security

Constraints of Internet Governance

Constraints are factors that make effective Internet governance difficult.

1. Lack of Global Cooperation

Countries often disagree on cyber laws and policies.

2. Different National Laws

Cyber laws vary from country to country, complicating enforcement.

3. Privacy vs National Security

Governments may seek access to encrypted data for security, while users demand privacy.

4. Limited Technical Expertise

Many organizations lack trained cyber security professionals.

5. High Implementation Cost

Strong cyber security infrastructure requires significant investment.

6. Lack of Awareness

Many users fall victim to scams due to poor cyber hygiene.

7. Fast-Changing Technology

Policies become outdated quickly as technology evolves.

8. Anonymous Internet Usage

Attackers can hide using: VPNs Proxy servers The Onion Router (Tor)

This makes attribution difficult.

9. Weak International Cyber Laws

Many countries lack comprehensive cyber legislation or extradition agreements.

10. Resource Constraints

Developing countries may face shortages of: Budget Skilled personnel Modern technology

Computer Criminals:

Explanation:

Computer criminals are **individuals** or **groups** who use computers and the internet to commit **illegal activities**. These crimes can include **hacking, online fraud, identity theft, data breaches**, and unauthorized access to sensitive systems.

These criminals may **work alone, in groups**, or as part of larger cybercrime networks. Their goal is often financial gain, data theft, or causing disruption.

Criminal Type	Main Goal	Example
Black Hat Hacker	Steal or damage data	Hacking a bank
Script Kiddie	Fun or fame	Using hacking tools
Phisher	Steal credentials	Fake bank email
Cyber Terrorist	Cause fear/disruption	Power grid attack

Insider Threat	Misuse authorized access	Data theft by employee
Identity Thief	Financial fraud	Using stolen card details
Spammer	Spread scams/malware	Fake lottery emails
Ransomware Attacker	Demand ransom	Encrypting company files

Example:

Hacking E-commerce for Credit Card Details

- **What Happens:** A hacker infiltrates an e-commerce website's server and steals customer credit card information stored in the database.
- **Impact:**
 - Stolen data is sold on the dark web.
 - Victims may lose money or suffer identity fraud.

Assets and Threat:

Asset:

Anything valuable to an organization or individual that must be protected.

Examples: Data, intellectual property (IP), patient records, software systems, hardware.

Threat:

Any potential danger or event that can exploit a vulnerability and cause harm or loss to an asset.

Examples: Hacking, theft, data breaches, malware, natural disasters.

Real-time Example:

Protecting hospital records from ransomware

- **Asset:** Electronic Health Records (EHR) of patients.
- **Threat:** Ransomware attack that encrypts the records and demands payment to restore access.
- **Impact:** Can delay medical treatment, violate privacy laws (e.g., HIPAA), and cause financial loss.

Examples of Assets

Hardware: Computers, servers, laptops, routers, switches.

Software: Operating systems, applications, databases.

Data: Customer records, passwords, bank information, research data.

Networks: Wi-Fi, LAN, cloud infrastructure.

People: Employees, customers, administrators.

Services: Email servers, websites, online banking systems.

Reputation: Company's brand image and customer trust.

Examples of Threats

- ✓ Malware (Viruses, Worms, Trojans)
- ✓ Phishing attacks

- ✓ Ransomware
- ✓ Hackers and cybercriminals
- ✓ Insider threats
- ✓ Natural disasters (floods, fires)
- ✓ Hardware failures
- ✓ Human errors

Discuss the motives of attackers in cybercrimes with examples.

Motive of attackers

The **motive of attackers in cybersecurity** is the reason why cybercriminals or hackers perform cyberattacks. Different attackers have different goals behind their actions.

1. Financial Gain

Explanation:

Attackers aim to steal money or financial information (like credit card numbers, banking credentials) or demand ransom.

Examples:

- **General:** A hacker steals credit card details and sells them on the dark web.
- **Real-time: Ransomware attack on WannaCry (2017)** locked systems and demanded payment in Bitcoin from hospitals and corporations.

2. Data Theft / Corporate Espionage

To steal sensitive personal, corporate, or government data for competitive or political advantage.

Examples:

- ✓ **General:** Competitors hiring hackers to steal trade secrets.
- ✓ Personal information (Aadhaar, PAN, passwords)
- ✓ Company trade secrets
- ✓ Customer databases
- **Real-time: The Equifax breach (2017)** exposed personal data of over 147 million people.

3. Hacktivism (Political Reasons)

Explanation:

Hackers break into systems to promote political or social agendas. Usually done by groups who disagree with certain policies or actions.

Examples:

- **General:** Defacing a government website to protest a law.
- Defacing government websites Leaking confidential documents Social campaigns through hacking
- **Real-time: Anonymous** hacking government and corporate sites to protest censorship or corruption

4. Cyber Warfare

Explanation:

State-sponsored attacks between countries to disrupt, spy, or cause chaos in critical infrastructure. (Nation-state attackers target other countries for intelligence gathering or disruption)

Examples:

- ✓ Attacking power grids
- ✓ Spying on government agencies
- ✓ Targeting military networks
- **Real-time: Stuxnet worm** allegedly created by the U.S. and Israel to sabotage Iran's nuclear program.

5. Personal Revenge / Grudge

Explanation:

An individual attacks an organization or person due to personal conflict or dissatisfaction.

Examples:

- ✓ A fired employee disables a company's servers.
- ✓ Deleting company files
- ✓ Leaking confidential information
- ✓ Sabotaging systems
- **Real-time:** Insider attacks where employees leak data out of spite.

6. Fun / Challenge / Curiosity/ Fame and Recognition

Explanation:

Amateur hackers or students may break into systems to test their skills or out of curiosity.

Examples:

- ✓ Teenagers hacking school systems to change grades.
- ✓ Defacing websites and leaving their name
- ✓ Posting screenshots of hacked systems online
- **Real-time:** A 15-year-old hacked NASA computers out of curiosity (1999).

7. Ideological / Religious Motivation

Explanation:

Attackers target systems that go against their ideological or religious beliefs.

Examples:

- **General:** Attacking websites promoting views contrary to an attacker's beliefs.
- **Real-time:** Terrorist groups launching cyber attacks to spread propaganda.

8. Competition Sabotage

Explanation:

Disrupting or damaging a competitor's digital infrastructure to gain market advantage.

Examples:

- **General:** Flooding a competitor's site with a DDoS attack during a product launch.
- **Real-time:** Alleged cyber attacks on rival companies during e-commerce sales.

Active attacks, Passive attacks

1. Active Attacks

Explanation:

In **active attacks**, the attacker **modifies, disrupts, or destroys** data or systems.

These attacks involve **direct interaction** with the target and can cause **damage or loss**.

Goal:

To alter system operations, corrupt data, or disrupt services.

Examples:

- **General Example:**
A hacker alters a file being transmitted over a network.
- **Real-time Example:**
Denial of Service (DoS) attack that floods a website, making it crash and go offline (e.g., GitHub DDoS attack in 2018).

Type of Active Attack	Brief Explanation	Example
Masquerade Attack	Attacker pretends to be an authorized user.	Logging in using someone else's stolen password.
Replay Attack	Attacker captures and retransmits valid data to gain access.	Recording a login request and sending it again later.
Modification of Messages	Attacker alters the contents of a message during transmission.	Changing a bank transfer amount from ₹1,000 to ₹10,000.
Denial of Service (DoS) Attack	Attacker makes a system or service unavailable to legitimate users.	Flooding a website with traffic so it crashes.

Passive Attacks

Explanation:

In **passive attacks**, the attacker **monitors or intercepts** data without altering it.

These attacks are often **hard to detect** because they don't affect system functionality.

Goal:

To **gain unauthorized access** to information without being noticed.

Examples:

- **General Example:** Eavesdropping on network traffic to capture login credentials.
- **Real-time Example:**
Wi-Fi packet sniffing in public networks to steal usernames and passwords using tools like Wireshark.

There are **two main types of passive attacks**:

1. Release of Message Contents (Eavesdropping)

Definition:

The attacker secretly reads or listens to confidential information being transmitted between users.

Goal: Steal sensitive information.

Examples:

Reading unencrypted emails.

Capturing usernames and passwords on an unsecured Wi-Fi network.

Listening to VoIP calls.

How it works:

Sender —► Attacker (reads data) —► Receiver

2. Traffic Analysis

Definition:

Even if the data is encrypted, the attacker studies the **communication patterns**, such as who is communicating, how often, and how much data is being exchanged.

Goal: Gather intelligence from communication patterns.

How it works:

Encrypted Data ☐ Cannot Read

Communication Pattern ☒ Can Observe

Real-Life Example:

An attacker cannot read encrypted military messages but notices a sudden increase in communication between command centers, indicating possible military activity.

Feature	Release of Message Contents	Traffic Analysis
Reads actual data?	Yes	No
Modifies data?	No	No
Uses encryption bypass?	Usually targets unencrypted data	Studies metadata only
Main objective	Steal information	Gather intelligence

Difference between Active Attack and Passive Attack

Feature	Active Attack	Passive Attack
Action	Modifies or disrupts data	Monitors or listens to data
Detectable	Often detectable	Hard to detect
Damage	Can cause serious damage	No direct damage, but breach of privacy
Intent	Disruption or manipulation	Surveillance or information theft

Software Attacks

Software attacks target **applications, operating systems, or code**. These attacks exploit **software vulnerabilities** to gain unauthorized access, steal data, or disrupt systems.

Common Methods:

- ✓ Malware (virus, worms, Trojans)
- ✓ Phishing
- ✓ Exploiting software bugs
- ✓ SQL injection
- ✓ Ransomware

Examples:

- **General Example:**

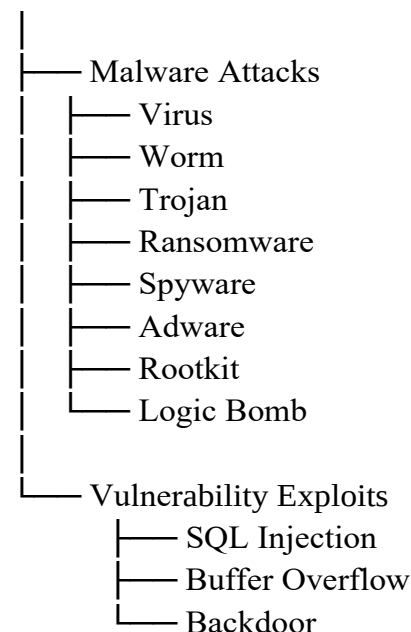
A user clicks on a fake link and installs spyware unknowingly.

- **Real-time Example:**

Log4j vulnerability (2021):

Attackers exploited a flaw in the Log4j Java library to execute remote code on servers.

Software Attacks



Hardware Attacks

Hardware attacks target the **physical components** of a system like **CPUs, RAM, USBs, or network devices**. These can involve **physical tampering** or **malicious hardware/software combinations**.

Common Methods:

- ✓ Inserting malicious USB devices
- ✓ Firmware tampering
- ✓ Supply chain attacks
- ✓ Side-channel attacks

Examples:

- **General Example:**
An attacker plugs in a USB drive with malware into a company computer.
- **Real-time Example:**
Stuxnet worm (2010):
Targeted Iran's nuclear centrifuges by exploiting both software and hardware vulnerabilities.

Hardware Attacks

- Theft Attacks
- Keylogger Attacks
- USB Attacks
- Hardware Tampering
- Firmware Attacks
- Side-Channel Attacks
- Device Sabotage
- Supply Chain Attacks

- ✓ **Active Attack:** An attack that modifies or disrupts system resources.
- ✓ **Passive Attack:** An attack that observes or collects information without altering it.
- ✓ **Software Attack:** An attack that exploits software vulnerabilities.
- ✓ **Hardware Attack:** An attack that physically compromises computer hardware.
- ✓ **Spectrum of Attacks:** The entire range of cyber threats and attack methods.
- ✓ **Taxonomy of Attacks:** The systematic classification of cyberattacks into different categories

Taxonomy of Attacks

Definition:

A **taxonomy of attacks** is a structured classification system that organizes cyberattacks based on **how they occur, what they target, and what they intend to do**.

This helps cybersecurity professionals understand threats better and plan defenses accordingly.

1. Based on Attacker's Intent

Type	Explanation	Example
Passive Attack	Attacker monitors or listens to communications without altering them.	Eavesdropping on unencrypted Wi-Fi to steal passwords.
Active Attack	Attacker alters, disrupts, or damages data or systems.	Injecting malware into a government server.

2. Based on Attack Origin

Type	Explanation	Example
Insider Attack	Originates from within the organization (e.g., employee misuse).	Employee leaking financial records.
Outsider Attack	Performed by someone outside the organization (e.g., hacker).	Hacker breaching a school website.

3. Based on Attack Technique

Type	Explanation	Example
Social Engineering	Exploits human behavior to trick users.	Phishing email that mimics a bank message.
Malware Attack	Uses malicious software to harm systems.	Trojan horse hidden in a fake app download.
Web-Based Attack	Exploits web apps or servers .	SQL injection to steal user data from a website.
Network Attack	Targets network protocols or connections .	Man-in-the-middle attack intercepting data.

4. Based on Target

Type	Explanation	Example
Data Attack	Aims to steal or manipulate information.	Ransomware encrypting company files.
System Attack	Tries to damage or disable systems .	Virus corrupting OS files.
Service Attack	Disrupts access to online services .	DDoS attack on a payment gateway.

5. Based on Tools Used

Type	Explanation	Example
Software Attack	Involves software tools or exploits.	Exploit kits targeting browser vulnerabilities.
Hardware Attack	Targets physical components.	Malicious USB device planting spyware.

Summarize

Category	Subtypes	Example
Intent	Passive, Active	Packet sniffing, ransomware
Origin	Insider, Outsider	Employee data leak, external hacker
Technique	Social engineering, Malware, Web-based	Phishing, Trojans, SQL injection
Target	Data, System, Service	Data breach, virus, DDoS
Tools	Software, Hardware	Keyloggers, Malicious chip

Spectrum of Attacks

Spectrum of Attacks is the complete range of cyber threats and attack techniques used to compromise the confidentiality, integrity, and availability of systems and data

Attack Type	Confidentiality	Integrity	Availability
Passive Attack	✓	☐	☐
Active Attack	✓	✓	✓
Software Attack	✓	✓	✓
Hardware Attack	✓	✓	✓
Network Attack	✓	✓	✓
Social Engineering	✓	☐	☐
Physical Attack	✓	✓	✓
Insider Attack	✓	✓	✓

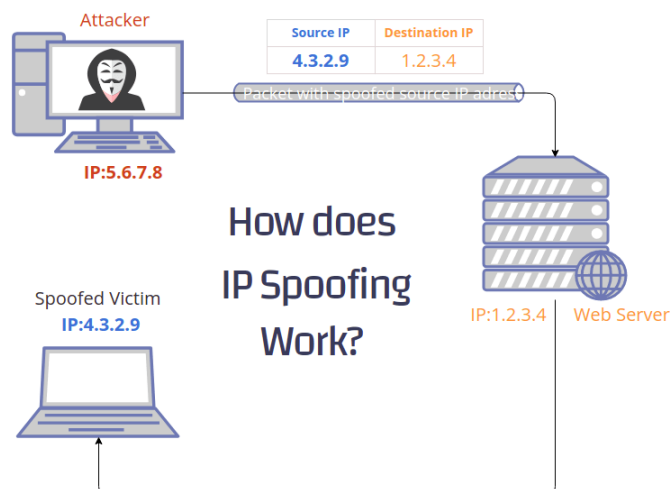
IP Spoofing:

Define IP spoofing. Explain how it works and methods to prevent it.

IP Spoofing is a technique where an attacker **fakes the source IP address** of a packet to make it look like it's coming from a **trusted source**.

The goal is to **bypass security measures**, impersonate legitimate users, or launch further attacks.

IP Spoofing is the process of creating IP packets with a forged source IP address to conceal the sender's identity or impersonate another device on a network.



How It Works

When devices communicate over a network (like the Internet), they use **IP addresses** to identify each other.

In IP spoofing, the attacker:

1. Crafts packets with a **false IP address** (spoofed IP).
2. Sends these packets to a target system.
3. The target believes the data is from a **trusted source** and may **respond, accept, or process** it without suspicion.

Goals of IP Spoofing

- ✓ Bypass firewalls and IP-based authentication
- ✓ Impersonate trusted systems
- ✓ Launch DDoS attacks
- ✓ Intercept or manipulate communications

Types of Attacks Using IP Spoofing

Attack Type	Explanation	Example
DoS/DDoS	Attackers send a flood of spoofed packets to overload a server.	Sending fake requests from thousands of spoofed IPs to crash a website.
Man-in-the-Middle (MITM)	Spoofed IPs trick users or devices into connecting to the attacker.	Intercepting banking login data by acting as a fake IP of a bank server.
Session Hijacking	Spoofing an IP to take over an active session.	Stealing a user's session with a web service by mimicking their IP address.

Real-Time Example

- **Real-Time Case:**
- In a DDoS attack against a government website, attackers used **spoofed IP addresses** to send a high volume of traffic, making it impossible for real users to access the site. The spoofed IPs made it hard to trace the origin.

Defences against IP Spoofing

Method	Explanation
Packet Filtering	Firewalls and routers examine incoming packets and block packets coming from suspicious, invalid, or private IP addresses.
Ingress/Egress Filtering	Routers ensure that packets entering (Ingress) or leaving (Egress) the network have legitimate source IP addresses.
Encryption & Authentication	Security protocols like IPsec verify the identity of the sender and ensure packets are authentic and have not been altered.
Network Monitoring	Network administrators continuously monitor traffic and detect unusual patterns that may indicate spoofing attacks.

Methods of Defense

Definition:

Cyber defense methods are strategies, tools, and practices used to **protect systems, networks, and data** from cyberattacks, unauthorized access, and data breaches.

1. Firewall Protection

Explanation:

A firewall monitors and controls **incoming and outgoing network traffic** based on security rules.

Examples:

- **General:** A firewall blocking access to unknown or blacklisted IP addresses.
- **Real-Time:** A company firewall blocking traffic from suspicious countries to prevent brute-force login attempts.

2. Antivirus and Anti-malware Software

Explanation:

These programs detect, block, and remove malicious software like viruses, worms, and trojans.

Examples:

- **General:** Antivirus detects and removes a Trojan hidden in an email attachment.
- **Real-Time:** Windows Defender stopping a ransomware file before it encrypts system data.

3. Authentication and Access Control

Explanation:

Ensures only **authorized users** access sensitive data or systems.

Examples:

- **General:** Using **passwords and multi-factor authentication (MFA)**.
- **Real-Time:** Google account requiring OTP on your phone after entering a password.

4. Encryption

Explanation:

Converts data into unreadable form to protect it from unauthorized access during transmission or storage.

Examples:

- **General:** HTTPS encrypts web traffic.
- **Real-Time:** WhatsApp end-to-end encryption prevents third parties from reading messages.

5. Intrusion Detection and Prevention Systems (IDS/IPS)

Explanation:

Monitors network activity for **suspicious behaviour** and either alerts (IDS) or blocks (IPS) it.

Examples:

- **General:** IDS flagging unusual login attempts at midnight.
- **Real-Time:** IPS blocking a SQL injection attempt on a company's web portal.

6. User Awareness and Training

Explanation:

Educating users to **recognize and avoid** cyber threats such as phishing, malware, and scams.

Examples:

- **General:** Teaching employees not to click on unknown email links.
- **Real-Time:** A bank warning customers not to share OTPs or passwords with anyone.

7. Regular Software Updates and Patch Management

Explanation:

Fixing **known vulnerabilities** in operating systems and applications through updates.

Examples:

- **General:** Updating Windows OS to fix a security bug.
- **Real-Time:** Apple releases a patch to block spyware like Pegasus.

8. Backup and Disaster Recovery

Explanation:

Creating secure **copies of data** so that systems can be restored in case of attack or failure.

Examples:

- **General:** Daily backup of company databases.
- **Real-Time:** A hospital restores patient records from backup after a ransomware attack.

9. Security Policies and Auditing

Explanation:

Setting internal **rules and procedures** for handling data and conducting **regular checks**.

Examples:

- **General:** Company policy enforcing password changes every 90 days.
- **Real-Time:** Audit logs detect that an employee tried to access restricted HR files.

Security Models in Cyber Security:

Definition:

Security models are formal frameworks that define **rules, policies, and principles** to maintain **confidentiality, integrity, and access control** in computing systems.

They help design secure systems by specifying **who can access what, and how**.

1. Bell-LaPadula (BLP) Model – Focus: Confidentiality

Explanation:

Bell-LaPadula (BLP) Model is a security Model used to control access to sensitive data in Systems

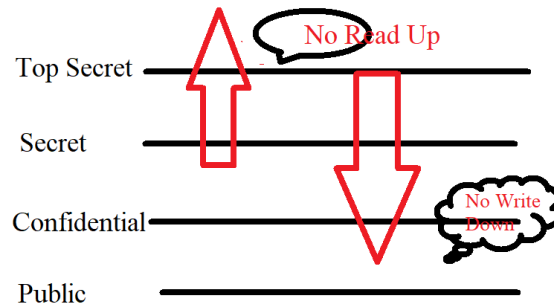
- ✓ Used mainly in military and government systems to **prevent unauthorized disclosure of data**.

It enforces two main rules:

- **No Read Up (NRU)** – Users can't read data at a higher security level. - Simple Security Rule
- **No Write Down (NWD)** – Users can't write data to a lower level (to prevent leaks). - Star Property Rule

Example: -

A "Confidential"-level employee cannot read "Top Secret" files or write "Confidential" data to "Public" files.



2. Biba Model – Focus: Integrity

Explanation:

Ensures that data is **not improperly modified** by enforcing:

- **No Write Up (NWU)** – Users can't write to higher integrity levels.
- **No Read Down (NRD)** – Users can't read data from lower integrity levels.

Example:

A software developer (low integrity) can't update system kernel files (high integrity), but a system admin can.

Difference between Bell-LaPadula Model & Biba Model

Feature	Bell-LaPadula Model	Biba Model
Protects	Confidentiality	Integrity
Goal	Prevent unauthorized disclosure	Prevent unauthorized changes
No Read	No Read Up	No Read Down
No Write	No Write Down	No Write Up
Used In	Military, defense, classified government systems	Banking, hospitals, examination systems

3. Clark-Wilson Model –

Focus: Integrity with Real-World Controls

Explanation:

Uses **well-formed transactions** and **separation of duties**. It enforces that only authorized users can make valid changes to the data through specific applications.

Example:

In a banking system, a clerk inputs a transaction, but a supervisor must approve it before it is processed.

The **Clark-Wilson Model** is an **integrity-based security model** designed to ensure that **data remains accurate, consistent, and protected from unauthorized modification** through **well-defined business rules and controlled transactions**

Difference between Clark-Wilson Model & Biba Model

Feature	Clark-Wilson	Biba
Goal	Protect Integrity	Protect Integrity
Data Modification	Only through authorized transactions	Based on integrity levels
Main Rules	Well-formed transactions, Separation of Duties, Auditing	No Read Down, No Write Up
Best Used In	Banking, payroll, hospitals, ERP, accounting	Military and general integrity-based systems

4. Brewer-Nash Model (Cinderella Model) – Chinese Wall

Focus: Conflict of Interest

Explanation:

Designed to prevent **conflict of interest** by changing access based on **user's previous actions**.
Common in commercial settings.

Example:

If a consultant accesses Company A's data, they can't later access Company B's data (if both are competitors).

5. Access Control Matrix Model –

Focus: Permissions

Explanation:

Represents **who (subject)** can do **what (operation)** on **which resources (object)** using a matrix.

Who can do **what** on **Which** Resources

Example:

- Alice can Read/Write File1
- Bob can only Read File1
- Admin can Read/Write/Delete File1

6. Take-Grant Model –

Focus: Rights Management

Explanation:

Describes how **rights (permissions)** can be transferred between subjects (users or programs) in a secure system.

Example:

A file owner (subject) grants read access to another user but restricts the ability to further share it.

Explain Risk Management in cyber security.

Definition:

Cybersecurity risk management is the process of **identifying, analyzing, evaluating, treating, and monitoring cyber risks** to protect an organization's digital assets(data, systems, and networks) from attacks.

It ensures organizations protect **what matters most** by managing potential cyber risks.

Formula of Risk

$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

Where:

- **Threat** = Something that can cause harm
- **Vulnerability** = Weakness in the system
- **Impact** = Damage caused if exploited

Steps in Risk Management Process

Step 1: Risk Identification

Explanation:

Risk Identification is the process of **finding and listing** all possible risks(threats and vulnerabilities.) that may affect an organization.

Example:

- **General:** Identifying outdated software as a potential entry point.
- **Real-Time:** Finding that employees are using weak passwords.

Step 2: Risk Assessment (Risk Analysis)

Explanation: Evaluate the **likelihood** and **impact** of each risk.

Likelihood – How likely is the risk to occur?

Impact – How severe will the damage be if it occurs?

Example:

- **General:** Assessing that a ransomware attack is highly likely and would severely disrupt services.
- **Real-Time:** An e-commerce site assesses that a data breach would lead to financial and reputational loss.

Risk	Likelihood	Impact
Weak Password	High	High
Phishing Email	High	Medium
Earthquake	Low	High

Step 3: Risk Evaluation

Definition

Risk Evaluation is the process of **comparing risks and deciding** which risks require immediate attention based on their severity.

Which risk should be handled first?

Explanation: Apply controls to reduce or eliminate the risk.

Example:

- General: Installing firewalls and antivirus software.
- Real-Time: Enforcing multi-factor authentication (MFA) after detecting phishing attempts.

Step 4: Risk Treatment (Risk Mitigation)

Risk Treatment involves selecting and implementing appropriate measures to reduce or manage risks.

Common Risk Treatment Strategies

1. Avoid the Risk

Eliminate the activity that creates the risk.

2. Reduce (Mitigate) the Risk

Apply security controls to reduce the likelihood or impact.

3. Transfer the Risk

Shift the financial or operational responsibility to another party.

4. Accept the Risk

Accept the risk if it is minor and the cost of preventing it is higher than the potential loss.

Risk Management Strategies

Strategy	Meaning	Example
Risk Avoidance	Eliminate the risk source	Not storing sensitive data online
Risk Reduction	Lower the chance or impact	Using antivirus and regular backups
Risk Transfer	Shift the risk to another party	Buying cyber insurance
Risk Acceptance	Accept minor risks due to low impact	Accepting downtime for minor services

Step 5: Risk Monitoring

Explanation: Continuously observe systems for new or changing threats. and whether existing security controls are effective.

Example:

- General: Regularly updating antivirus definitions.
- Real-Time: Using a Security Information and Event Management (SIEM) tool to detect suspicious activity.

Step 6: Risk Review & Reporting (Documentation)

Explanation: Review the risk management plan and update it as needed.

Example:

- General: Quarterly risk audits.
- Real-Time: After a cyberattack, updating security policies to prevent recurrence.

Activities

- ✓ Maintain a Risk Register
- ✓ Prepare Incident Reports
- ✓ Create Audit Reports
- ✓ Update Security Policies
- ✓ Inform management about major risk

Cyber Threats: Warfare, Crime, Terrorism, Espionage in Cyber Security

These are **major types of cyber threats** based on the **intent** and **actors** involved.

Each has a distinct motive — from damaging critical infrastructure to stealing sensitive information.

A Cyber Threat is any malicious activity that attempts to damage, steal, disrupt, or gain unauthorized access to digital systems or information

1. Cyber Warfare

Explanation:

Cyber warfare involves attacks by **nation-states or government-sponsored groups** to **disrupt, damage, or control another country's digital infrastructure** during political or military conflict.

General Example:

- Launching attacks on an enemy's power grid or military network. Satellites Airports Government websites

Real-Time Example:

- **Stuxnet (2010):** A U.S.-Israeli cyber weapon used to damage Iran's nuclear centrifuges.
- **Russia-Ukraine cyberattacks:** attacks on government services, communications, and critical infrastructure alongside conventional military operations.

2. Cyber Crime

Explanation:

Cyber crime includes **financially motivated attacks** by individuals or groups to **steal, defraud, or extort**.

Cyber Crime refers to illegal activities carried out using computers, networks, or the Internet.

General Example:

- Spreading ransomware to lock files and demand payment.

Real-Time Example:

- **WannaCry Ransomware Attack (2017):** Affected over 200,000 systems worldwide, demanding ransom in Bitcoin.

3. Cyber Terrorism

Explanation:

Cyber terrorism involves **disruptive or destructive attacks** by **ideologically motivated groups or individuals** (e.g., extremist organizations) to cause fear, damage, or panic.

General Example:

- Defacing government websites to spread extremist messages.

Real-Time Example:

- ISIS-affiliated hackers launching cyberattacks on U.S. military websites and leaking personnel data.

Cyber Terrorism is the use of cyber attacks to create fear, panic, disruption, or harm for political, ideological, or religious purposes.

4. Cyber Espionage

Explanation:

Cyber espionage is the act of **spying or stealing confidential data** from organizations or governments or military organizations or research institutions usually by **state actors or competitors**.

General Example:

- Hacking into a government agency to extract intelligence reports.

Real-Time Example:

- **APT10 (China):** Hacked global companies and government agencies to steal trade secrets and personal data.

All types comparison

Type	Motive	Actor	Real-Time Example
Cyber Warfare	National disruption	Government	Stuxnet attacking Iranian nuclear sites
Cyber Espionage	Data theft/intelligence	Nation-state/corporate spies	APT10 stealing trade secrets
Cyber Terrorism	Fear, political agenda	Extremist groups	ISIS hacking U.S. military sites
Cyber Crime	Financial gain	Hackers/criminals	WannaCry ransomware

Cyber Security Policy?

A **Cyber Security Policy** is a **formal document** that outlines an organization's rules, practices, and procedures for **protecting its digital assets** (data, systems, and networks) from cyber threats. It guides employees and stakeholders on how to **behave securely** and how to **respond to security incidents**.

Purpose of Cyber Security Policy

- ✓ To **prevent unauthorized access** or data breaches
- ✓ To define **acceptable use of technology**
- ✓ To ensure **compliance** with legal and industry standards
- ✓ To guide the **response and recovery** from cyber incidents

Component	Explanation	Example
Access Control Policy	Who can access what systems and data	Only HR can access employee personal records
Password Policy	Rules for creating and managing passwords	Minimum 12 characters + special symbols
Data Protection Policy	How data is collected, stored, and secured	All sensitive data must be encrypted
Internet & Email Use Policy	Rules for using internet and communication tools	No personal downloads from untrusted websites
Incident Response Plan	Steps to take during a security breach	Notify IT, isolate system, report the breach

Remote Work Policy	Security rules for accessing data remotely	Use VPN and MFA for remote access
Software Update Policy	Regular patching and updating of systems	Apply OS updates within 7 days of release

Example:

A company's cybersecurity policy may state that:

- ✓ Employees **must not share passwords**,
- ✓ **All sensitive emails must be encrypted**,
- ✓ Systems must **lock automatically** after 5 min of inactivity.

Real-Time Example:

A bank's policy might include:

- ✓ **Two-factor authentication (2FA)** for every login,
- ✓ Employees **cannot plug in USB drives** from outside,
- ✓ **Monthly audits** of access logs.

Benefits of Having a Cyber Security Policy

- ✓ Reduces risk of human error and insider threats
- ✓ Helps respond quickly to incidents
- ✓ Protects company reputation and customer trust
- ✓ Ensures compliance with **laws like GDPR, HIPAA, IT Act**